

Lab 07 – Risk Matrix Workshop – Solutions

Industrial Security (Bachelor) • Maps to Section 07 • 60 min

LAB 07

🎯 Goal

Lecturer / TA reference: sample plant scenario, a fully populated 5×5 matrix with five worked risks, justification language, facilitation notes for the inevitable colour argument, and a grading rubric.

✓ Sample scenario – “Acme Specialty Batch #3”

A small contract-manufacturing site: one jacketed batch reactor (2 m³), single SIS logic solver (SIL 2, separate from BPCS), two operators per shift across three shifts, one engineering workstation, one Historian VM, and an MES that pushes batch records to the customer portal over the internet (TLS, no VPN). Annual revenue from this line ≈ EUR 8 M; a lost batch is worth EUR 40 k.

✓ Sample 5×5 matrix (five plotted risks)

Likelihood: **1** Rare, **2** Unlikely, **3** Possible, **4** Likely, **5** Very Likely. Consequence: **1** Insignificant, **2** Minor, **3** Moderate, **4** Major, **5** Catastrophic.

	C1	C2	C3	C4	C5
L5		R5			
L4			R2		
L3			R4	R1	
L2					R3
L1					

- **R1 – Unauthenticated Modbus write changes a reactor setpoint.** L = 3 (Possible): Modbus/TCP has no auth and the BPCS network has been touched by contractor laptops. C = 4 (Major, safety): an out-of-band setpoint can drive an exothermic runaway before the SIS trips; SIS is independent but operators rely on BPCS alarms for early warning. **Red.**
- **R2 – USB-borne malware reaches the engineering workstation.** L = 4 (Likely): USB transfer is the documented update path for the PLC vendor toolchain. C = 3 (Moderate): malware on the EWS most plausibly corrupts project files and forces a reload, costing ~1–2 batches; safety unaffected because the SIS is air-gapped. **Orange.**
- **R3 – Vendor remote-access account compromised.** L = 2 (Unlikely): account exists, MFA is on, used ~6×/year. C = 5 (Catastrophic): vendor account can push firmware to both BPCS *and* SIS logic solver – single point of compromise reaches the safety layer. **Red.**
- **R4 – Historian database encrypted by ransomware.** L = 3 (Possible): Historian VM is domain-joined and patched on the IT cadence. C = 3 (Moderate): batch records for billing are mirrored to the MES (separate DB) so revenue is preserved; loss is ~90 days of trend data needed for process tuning and audits. **Yellow.**
- **R5 – Operator misconfigures a valve via HMI.** L = 5 (Very Likely): happens on average once a quarter per the site’s deviation log. C = 2 (Minor): single-batch loss, caught by SIS or downstream QA; no safety, no environmental release. **Yellow.**

✓ Facilitation notes – let the argument run

The point of the workshop is **not** to converge on the “correct” matrix. Two competent teams given the same scenario will produce different placements because likelihood is a frequency

estimate over a population of one and consequence depends on what the team values (lives, money, license-to-operate). *That disagreement is the deliverable.* Do not arbitrate cell colours – ask each team to defend their L and C scores in one sentence, then move on. Time-box Step 2 at 25 min; teams will happily argue R1 for the full hour if you let them.

✓ Common student mistakes

- **Everything is Major.** Default-Major inflation makes the matrix useless; force a separation between “batch loss” (Moderate) and “injury / release” (Major+).
- **Conflating safety and financial impact on one axis.** Either run two parallel matrices (safety, business) or define consequence as “worst of the four sub-dimensions” – and write it down. Mixing the two silently is the most common defect.
- **Treating colour bands as objective.** Red/orange/yellow/green are *risk appetite*, not physics. A pharma site and a parts shop will paint the same cell differently and both are right.
- **Confusing inherent and residual risk.** Ask: “Did you score before or after the existing safeguards?” Most teams quietly do residual – make them say so.
- **Likelihood as a probability percent.** Students try to write “35 %”; the scale is ordinal, not interval. Define each level in plain language (e.g. L4=“expect at least once per year”).

✓ Discussion prompts for the closing 10 minutes

- “*Team A put R1 in red, Team B put it in orange. Whose risk appetite is wrong?*” – Neither. The matrix is a communication tool, not a truth machine; its job is to make the disagreement visible so management can set policy.
- “*You scored R3 as Unlikely because MFA is on. What if the vendor’s IdP is breached?*” – Introduces dependency risk and forces the team to articulate the assumption behind their L score.
- “*Which of your top-three risks would move two cells if the SIS were on the same network as the BPCS?*” – Drives home that architecture choices change the matrix, not just controls.
- “*If you ran this workshop again next year, which risk would have moved most?*” – Surfaces velocity / trend, which a static matrix hides.

📊 Grading rubric

- **2 pts** – Likelihood and Consequence scales defined in plain language with anchors per level (not bare numbers).
 - **4 pts** – Ten risks plotted in the matrix; **full marks for any placement** that carries a defensible one-sentence justification for both L and C. Deduct 0.5pt per risk that is placed by gut feel with no justification.
 - **2 pts** – Top three risks rendered as Cyber-HAZOP rows (guide word, deviation, cyber cause, existing safeguards, gap).
 - **1 pt** – Three mitigations with cost / time bands.
 - **1 pt** – 5-line CFO summary that argues for the investments in business language, not jargon.
- Total: **10 pts**. Do *not* deduct points for “wrong” colours – only for missing or unjustified placements. Award a bonus point if the team explicitly distinguished *inherent* vs. *residual* risk in their notation.